

IoT Security Assessment Report

Name: Solomon Mwaura

Date: March 15, 2026

1. Executive Summary

This assessment evaluates the **Smart City Traffic Management System** deployed by MetroTraffic Solutions. The assessment revealed a high-risk security posture characterized by systemic vulnerabilities including default credentials, outdated firmware, and unencrypted communication channels. The most critical risks involve the potential for unauthorized control of Smart Traffic Lights and unencrypted CCTV video streams. To prevent public safety incidents and data privacy violations, MetroTraffic must prioritize credential rotation, firmware patching, and network segmentation.

2. IoT Environment Mapping

The infrastructure consists of a multi-layered IoT ecosystem:

- **Perception Layer (Devices):** * **CityFlow-4000 Traffic Lights:** Connect via 5G/Ethernet.
 - **VisionEye-200 CCTV:** Connect via Wi-Fi/LTE.
 - **AutoSense-X3 Sensors:** Connect via Zigbee/Wi-Fi.
 - **Network Layer (Gateway):** **TrafficEdge-1000** aggregates data via Ethernet/5G.
 - **Communication Flow:** Data flows from edge devices to the Edge Gateway and subsequently to Cloud Analytics or Law Enforcement systems.
 - **Segmentation:** While a dedicated VLAN exists for IoT devices, "VLAN leakage" occurs as administrative workstations share access with the general municipal IT network.
-

3. Device Security Assessment

Device security is currently inadequate across all categories:

- **Authentication:** Critical reliance on default credentials (**admin/admin** for traffic lights and hardcoded keys for cameras). Administrators share login credentials, preventing accountability.
- **Firmware:** The CityFlow-4000 units are running firmware that is **22 months out of date**, leaving them vulnerable to publicly known exploits.
- **Physical Security:** The AutoSense-X3 sensors have **exposed USB ports**, facilitating local "Evil Maid" attacks where an attacker could manually inject malicious firmware.
- **Resilience:** No Role-Based Access Control (RBAC) is implemented, meaning any user with access has full system privileges.

4. Network & Communication Security Assessment

The network environment is highly permissive and poorly encrypted:

- **Protocol Vulnerabilities:** Use of **TLS 1.0** (deprecated/insecure) and **HTTP** for remote management interfaces allows for credential sniffing and Man-in-the-Middle (MitM) attacks.
- **Insecure Services:** The Edge Gateway has unnecessary and insecure ports open, specifically **Telnet** and **FTP**, which transmit data in plain text.
- **Encryption Weakness:** Vehicle sensors use AES-128; while not "broken," it is below the modern AES-256 standard required for high-security infrastructure. SSH keys are shared across multiple devices, meaning one compromised device grants access to the entire fleet.

5. Data Security & Privacy Assessment

MetroTraffic is at high risk of **GDPR** and **transportation law violations**:

- **Data at Rest:** The Edge Gateway fails to encrypt data at rest. If the gateway is physically stolen or digitally breached, all aggregated traffic and sensor data is readable.
- **Privacy:** CCTV video streams are unencrypted. An attacker on the Wi-Fi or LTE network can intercept live footage of citizens.
- **Retention:** There is **no automated deletion or anonymization** policy. Storing tracking logs indefinitely increases the legal liability and impact of a potential data breach.

6. IoT System Resilience & Attack Simulation

Potential attack scenarios include:

- **Signal Hijacking:** An attacker using the **admin/admin** credentials over HTTP to change traffic signal patterns, potentially causing physical accidents.
- **Surveillance Interception:** Intercepting unencrypted LTE camera feeds to track specific vehicles or individuals.
- **Firmware Injection:** Using the exposed USB ports on vehicle sensors to feed "ghost" congestion data to the cloud, causing the AI to malfunction and misdirect traffic city-wide.
- **Lateral Movement:** An attacker compromising a municipal IT workstation could cross over into the IoT VLAN due to poor network isolation.

7. Security Monitoring & Incident Response Review

- **Logging:** Logs are decentralized (stored only on individual devices). If a device is compromised and wiped, all forensic evidence is lost. There is no **SIEM** integration.

- **Alerting:** There is **zero real-time alerting**. An attacker could maintain access for months without detection.
- **Response:** There is no formal **Incident Response Plan**. The IT team lacks specific IoT forensics expertise, meaning they are unprepared to handle threats like Zigbee-based attacks or firmware rootkits.

8. Prioritization of Security Risks & Remediation Plan

Risk	Likelihood	Impact	Priority	Remediation Action
Default/Shared Credentials	High	Critical	1	Immediate rotation of all passwords; implement MFA on Gateways.
Unencrypted Traffic/Video	High	High	2	Enforce HTTPS/TLS 1.3 and encrypt CCTV LTE streams.
Outdated Firmware	Medium	Critical	3	Establish an automated patch management cycle for traffic lights.
Open Telnet/FTP Ports	High	Medium	4	Disable unnecessary ports on Edge Gateways; use SSH exclusively.
Physical USB Exposure	Low	High	5	Physically seal USB ports on sensors; enable secure boot.

9. Conclusion & Next Steps

The MetroTraffic IoT infrastructure is currently vulnerable to attacks that could result in loss of life, privacy breaches, and significant legal penalties. The **most critical risks** are the use of default credentials on traffic lights and the lack of encryption on public safety cameras.

Immediate Next Steps:

1. Change all default passwords and enable MFA on the TrafficEdge-1000 Gateway.
2. Update all CityFlow-4000 firmware to the latest version.
3. Shut down Telnet/FTP ports and transition management to HTTPS.
4. Develop a formal IoT-specific Incident Response Plan.